

Gestión de la Seguridad y Normativas

UD1 · 10 horas · ISO 27002 · ITIL · LOPDGDD · ENS

Contenidos de la UD1

- 1. Norma ISO/IEC 27002:2022 — Controles de seguridad de la información
- 2. Metodología ITIL v4 — Gestión de servicios TI
- 3. Marco legal: LOPDGDD y RGPD — Protección de datos personales
- 4. Normativas de seguridad física — CPD, perímetro, instalaciones
- 5. Relación entre normativas y su aplicación práctica en sistemas

ISO/IEC 27002:2022 — En Cifras

4

Temáticas

Organizativos · Personas · Físicos ·
Tecnológicos

93

Controles

Distribuidos en 4 categorías temáticas

11

Atributos

Para clasificar cada control (tipo,
propiedades, dominios...)

ISO 27002 — Las 4 Temáticas

5. Controles Organizativos (37)

Políticas, roles, gestión de activos, relaciones con proveedores, continuidad de negocio.

6. Controles de Personas (8)

Concienciación, formación, disciplina, acuerdos de confidencialidad, teletrabajo.

7. Controles Físicos (14)

Perímetro de seguridad, áreas seguras, escritorios limpios, monitorización física.

8. Controles Tecnológicos (34)

Control acceso lógico, cifrado, logs, monitorización, gestión vulnerabilidades, DLP.

ITIL v4 — Sistema de Valor de Servicio

- Marco de referencia para gestión de servicios TI
- Introduce el concepto de SVS (Service Value System)
- 4 dimensiones: Organización · Información · Socios · Flujos
- Principios guía: centrarse en el valor, colaborar, pensar holísticamente
- Prácticas clave: Gestión de incidentes, Gestión de la capacidad, ITSM

Aplicación en MF0490_3

- Gestión de incidentes → Alertas de monitorización
- Gestión de la capacidad → Control rendimiento y umbrales
- Eventos de seguridad → SIEM y correlación
- Gestión de la configuración → CMDB e inventario
- Gestión de acceso → IAM, AD, LDAP, SSO

LOPDGDD / RGPD — Implicaciones para Sysadmin

Principio	Qué implica en sistemas
Minimización de datos	Solo recoger logs/datos estrictamente necesarios
Integridad y confidencialidad	Cifrado en reposo y en tránsito. Control de acceso a logs
Limitación del plazo	Política de retención de logs (NIST: ≥ 1 año para logs críticos)
Notificación de brechas	Notificar a la AEPD en ≤ 72 horas
Derecho de supresión	Los sistemas deben permitir eliminación controlada de PII

Normativas de Seguridad Física

TIA-942

Diseño de CPD. Define 4 Tiers: Tier I (básico) → Tier IV (99.995% disponibilidad). Redundancia en subsistemas.

ISO 27001 — Anexo A.11

Seguridad física y del entorno: perímetro, zonas seguras, equipos desatendidos, política de escritorio limpio.

ENS — RD 311/2022

Esquema Nacional de Seguridad. Marco normativo obligatorio para sistemas de la AGE. Categorías: Básica, Media, Alta.

NFPA 75 / 76

Protección contra incendios en instalaciones IT. FM-200, NOVEC 1230, sistemas de detección temprana.

¿Cómo se relacionan entre sí?

- ISO 27001 (certificable, marco SGSI) + ISO 27002 (controles concretos a implantar) = sistema completo
- ITIL proporciona los procesos de gestión que operacionalizan los controles ISO
- LOPDGDD/RGPD añade el marco legal obligatorio para datos personales (parte de los controles organizativos)
- ENS es obligatorio para administraciones públicas; su estructura de controles es compatible con ISO 27001
- TIA-942 / NFPA operan a nivel de instalaciones físicas (capa inferior de la seguridad)
- → En la práctica: ISO 27001 certifica, ITIL opera, RGPD obliga, ENS regula, TIA-942 construye